Relatorio de Auditoria de Seguranca

Sputnik - Gestao de Oficina

Data da auditoria: 10/09/2026

Escopo auditado
Backend Spring Boot, entidades JPA/H2, API REST, controladores Thymeleaf, frontend React/Vite, configuracoes, documentacao, bundle estatico e historico Git.

Nota metodologica
RLS foi mapeado para isolamento por organizacao/dono nas queries JPA. Gates React foram cruzados com os endpoints REST. IDOR foi revisado em todos os handlers com IDs. Segredos foram pesquisados no codigo, configuracoes, documentacao, bundle e historico. XSS foi mapeado para JSX, Thymeleaf e HTML gerado no backend.

Classificacao: auditoria de codigo estatico. Somente achados reproduziveis pelo fluxo implementado foram reportados.

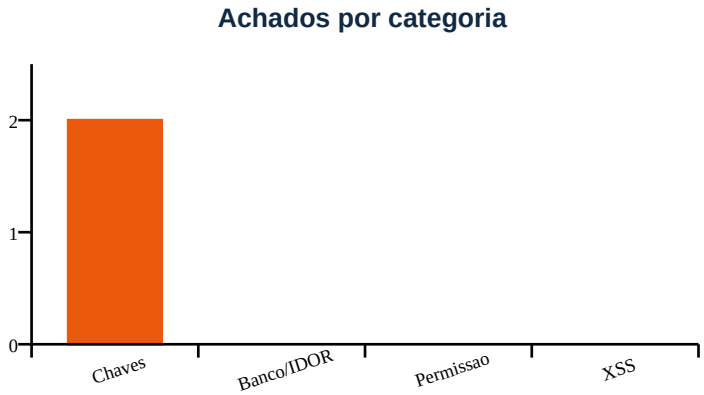
Resumo executivo

Foram confirmados **2 achados**: 1 de severidade alta e 1 de severidade media. Ambos se concentram no ciclo de senhas. Nao foram encontrados achados confirmados de isolamento multi-tenant, autorizacao apenas no navegador, IDOR ou XSS nesta revisao.

0 Critica	**1** Alta	**1** Media	**0** Baixa

Alta: 1

Media: 1



Achados confirmados

Severidade	Arquivo:linha	Descricao
ALTA	src/main/java/br/edu/fag/sputnik/auth/UsuarioService.java:102-118; README.md:54-61	**Credenciais de bootstrap fixas e publicadas** Ao detectar banco sem usuarios, o servico cria um administrador 'admin' e um balconista conhecidos, ambos com troca obrigatoria de senha desativada. O README publica as mesmas credenciais. Qualquer pessoa que alcance uma instalacao nova ou tenha seu banco reinicializado pode autenticar como administrador.
MEDIA	src/main/java/br/edu/fag/sputnik/auth/UsuarioService.java:22, 82-86; frontend/src/features/users/Users.tsx:19-22	**Senha temporaria de reset fixa e conhecida** O reset redefine qualquer Balconista para '12345678', senha exibida pela interface. Depois de um reset administrativo, quem souber o e-mail do usuario pode entrar com essa senha ate que o titular a altere. O endpoint e restrito a admin, mas a senha resultante e universal e previsivel.

A-01 - Credenciais de bootstrap fixas e publicadas

Severidade: ALTA
Local: src/main/java/br/edu/fag/sputnik/auth/UsuarioService.java:102-118; README.md:54-61

Ao detectar banco sem usuarios, o servico cria um administrador 'admin' e um balconista conhecidos, ambos com troca obrigatoria de senha desativada. O README publica as mesmas credenciais. Qualquer pessoa que alcance uma instalacao nova ou tenha seu banco reinicializado pode autenticar como administrador.

```
Trecho: criarUsuarioPadrao(... 'admin', 'Admin#2026!', Perfil.ADMIN, ...); e
usuario.setTrocaSenhaObrigatoria(false).
```

A-02 - Senha temporaria de reset fixa e conhecida

Severidade: MEDIA
Local: src/main/java/br/edu/fag/sputnik/auth/UsuarioService.java:22, 82-86; frontend/src/features/users/Users.tsx:19-22

O reset redefine qualquer Balconista para '12345678', senha exibida pela interface. Depois de um reset administrativo, quem souber o e-mail do usuario pode entrar com essa senha ate que o titular a altere. O endpoint e restrito a admin, mas a senha resultante e universal e previsivel.

```
Trecho: private static final String SENHA_TEMPORARIA_RESET = '12345678'; e
usuario.setSenhaHash(encoder.encode(SENHA_TEMPORARIA_RESET)).
```

Pontos fortes e cobertura

Isolamento / IDOR

O modelo JPA nao possui entidade organizacao, tenant ou dono de registros: e uma oficina unica compartilhada por funcionarios. Portanto RLS/filtro de tenant nao se aplica ao modelo atual. Todos os handlers com ID foram revisados. Rotas de OS exigem ORDENS antes de buscar ou alterar (OrdensApiController.java:67-155); rotas administrativas exigem perfil ADMIN (UsuariosApiController.java:36-88); backup valida nome por regex e normaliza o caminho (BackupService.java:62-68).

Permissao no navegador

Os gates React em App.tsx:47-113 foram cruzados com as APIs. PECAS, ORDENS, RELATORIO_MENSAL e REPOSICAO sao validados no servidor pelos controladores de API; Usuarios e Desenvolvedor usam ehAdministrador. Nao foi encontrado endpoint sensivel acessivel apenas por ocultacao de UI.

XSS

Nao ha dangerouslySetInnerHTML, innerHTML, eval ou new Function no fonte React. JSX usa escape automatico. Templates Thymeleaf usam th:text, nao th:utext. O HTML de impressao escapa &, <, >, aspas e apostrofos antes de inserir valores (DocumentoOsLayout.java:132-163).

Defesas adicionais

API mutavel exige token CSRF (ApiCsrfFilter.java:27-52); cookies sao HttpOnly e SameSite=Strict (application.properties:11-14); cabecalhos CSP, frame deny e nosniff sao definidos no filtro de seguranca.

Historico e deploy

O historico Git local possui um unico commit e foi pesquisado para credenciais. Nao ha Dockerfile, docker-compose, CI, Helm, charts ou Terraform no escopo versionado.

Observacao de escopo

Se o Sputnik evoluir para SaaS ou para varias oficinas, sera necessario adicionar organizacao_id as entidades e filtrar todas as listagens, buscas, agregacoes, exportacoes e buscas por ID no repositorio/servico. Isto e uma recomendacao arquitetural futura, nao um achado de vazamento confirmado no modelo de oficina unica atual.

Recomendacoes priorizadas

P1 - Remover bootstrap com senhas fixas. Exigir segredo de bootstrap por variavel de ambiente ou fluxo de criacao inicial de uso unico; falhar no startup se estiver ausente em perfil de producao; marcar a conta inicial para troca obrigatoria.

P1 - Revogar as credenciais expostas. Em ambientes ja inicializados, altere imediatamente as senhas de admin e balconista e invalide sessoes existentes. Remova a tabela de credenciais do README e, como elas ja entraram no Git, considere-as comprometidas.

P2 - Tornar o reset aleatorio. Gere senha temporaria criptograficamente aleatoria ou token de definicao de senha com expiracao e entrega fora da interface. Nunca mostre nem persista uma senha fixa de reset.

P3 - Preparar multitenancy se virar requisito. Criar contexto de organizacao e filtros obrigatorios por organizacao em JPA antes de oferecer dados de mais de uma oficina.

ISSUES PARA O GITHUB

Textos completos prontos para copiar e colar.

```
--- ISSUE 1 ---
# [Seguranca] Remover credenciais previsiveis criadas no bootstrap
**Labels sugeridas:** security, high
## Problema
```

Em banco vazio, a aplicacao cria automaticamente contas de Balconista e Administrador com credenciais conhecidas e sem troca obrigatoria de senha.

```
## Evidencia
```

src/main/java/br/edu/fag/sputnik/auth/UsuarioService.java:102-118
criarUsuarioPadrao(... 'admin', 'Admin#2026!', Perfil.ADMIN, ...)
src/main/java/br/edu/fag/sputnik/auth/UsuarioService.java:147-148
usuario.setTrocaSenhaObrigatoria(false);
README.md:54-61 publica as mesmas credenciais.

```
## Impacto
```

Tomada imediata de controle administrativo em uma instalacao nova ou banco reinicializado.

```
## Sugestao de correcao
```

Remover os literais, usar segredo de bootstrap externo de uso unico ou assistente de primeiro acesso, exigir troca obrigatoria e falhar no startup de producao se a configuracao segura nao existir.

```
## Criterios de aceite
```

- [ ] Nao existe senha de bootstrap no codigo, README ou bundle.
- [ ] Startup de producao nao cria admin com senha previsivel.
- [ ] Primeiro admin precisa definir senha segura.
- [ ] Credenciais atuais sao revogadas e documentacao atualizada.

```
--- FIM ISSUE 1 ---
```

```
--- ISSUE 2 ---
# [Seguranca] Substituir senha temporaria fixa no reset de usuario
**Labels sugeridas:** security, medium
## Problema
```

O reset de Balconista atribui a mesma senha conhecida a todas as contas e a interface a exibe antes da requisicao.

```
## Evidencia
```

src/main/java/br/edu/fag/sputnik/auth/UsuarioService.java:22, 82-86
private static final String SENHA_TEMPORARIA_RESET = '12345678';
usuario.setSenhaHash(encoder.encode(SENHA_TEMPORARIA_RESET));
frontend/src/features/users/Users.tsx:19-22 mostra a senha fixa.

```
## Impacto
```

Uma pessoa que conheca o e-mail de uma conta resetada pode autenticar durante a janela anterior a troca obrigatoria.

```
## Sugestao de correcao
```

Gerar segredo aleatorio por reset ou token de definicao com expiracao; entregar por canal autenticado e nunca mostrar senha global na UI.

```
## Criterios de aceite
```

- [ ] Cada reset gera valor/token unico com CSPRNG.
- [ ] O valor nao esta no codigo, docs ou bundle.
- [ ] Token expira e e inutilizado apos uso.
- [ ] Teste prova que dois resets nao produzem o mesmo segredo.

```
--- FIM ISSUE 2 ---
```